

THE OVERTON FRAMEWORK — Implementation & Evidence Companion

Version: 0.2 (February 2026)

This document is a fast-moving companion to the Overton Framework Canon. It operationalizes the Canon into concrete controls, evidence artifacts, and test/evaluation procedures.

- The **Canon** (LaTeX/PDF) is normative and scope-locked.
- This **Companion** is intended to iterate quickly as evidence practices mature.

Binding note: Where this Companion conflicts with the Canon, the Canon is authoritative; any such conflict **MUST** be resolved in the next Companion revision.

Change log (since 0.1): v0.2 adds explicit coercion/duress controls (neutral presentation + cryptographic erasure), adds stress variants for LAI/CLF, and introduces worked auditor walkthrough tables.

Definitions (Companion-local, Canon-aligned).

- **Essential Operation:** A workflow explicitly tagged as essential in the Canon’s scope declaration for a given system profile.
- **Destructive Action:** Any action whose nominal intent is removal or irreversible transformation of user data (including hard delete, key destruction, overwrite/replace).
- **Protected Record:** Any record marked as in-scope for coercion/PLS protections in the Canon’s data classification model.
- **Safer state (implementation meaning):** A state or posture change that reduces exposure and increases reversibility without increasing coercion risk. In S_3 -adjacent contexts, “safer” **SHOULD** prioritize silent hardening over obvious UI transformations. Non-prescriptive examples include deferring background sync, pausing nonessential network calls, and reducing outwardly conspicuous UI changes.
- **Coercion-relevant tell:** Any externally observable behavior change that plausibly signals concealment/protective activation to an observer (e.g., explicit “Safety Mode” banners, sudden conspicuous interface swaps, abrupt removal of expected content/affordances, or sudden and unexplained absence of normal notifications/content cues).
- **Network connectivity (for offline tests):** Any IP-based connectivity path (Wi-Fi, cellular, VPN, Ethernet) and any reliance on remote identity/authorization services. Non-IP local dependencies (e.g., Bluetooth peripherals) are not “network connectivity,” but **MUST** be explicitly documented when they are required to perform Essential Operations.
- **Reconstructive metadata:** Metadata that, alone or in combination, can reconstruct sensitive user behavior or content. Examples include fine-

grained timestamps, interaction sequences, keystroke/gesture timing, file sizes that correlate to content, contact graph edges, query terms, location traces, or identifiers that link multiple Protected Records.

- **Accessible mechanism:** A control that is reachable and operable using assistive technologies and constrained-input scenarios (keyboard-only, screen reader, switch control, large touch targets), with visible focus and predictable placement.

1) Protective Controls Catalog (Draft)

These control families operationalize the Canon's principles. Control statements below are intentionally concrete and testable.

PC-1 Local Authority Controls (Failure Containment)

- **PC-1.1** The system **MUST** remain usable for Essential Operations (as defined in the Canon's scope declaration) with no network connectivity (as defined above) for at least the documented **offline guarantee window** for that profile.
- **PC-1.2** Loss of remote services **MUST NOT** deny **local** read access to data associated with Essential Operations, and **MUST NOT** block local creation of new records required for Essential Operations.

PC-2 Reversibility Controls (Radical Reversibility)

- **PC-2.1** Except where explicitly declared irreversible in the Canon's scope declaration for the system profile, Destructive Actions **MUST** be reversible within a documented restoration window.
- **PC-2.2** Recovery **MUST** be available offline and **MUST NOT** require vendor intervention.
- **PC-2.3** Irreversible outcomes (e.g., hard deletion / garbage collection) **SHOULD** be staged so they require an explicit reaffirmation after a minimum dwell time, and/or a return to S_0/S_1 stable conditions.

PC-3 Exposure Minimization Controls (Minimum Necessary Exposure)

- **PC-3.1** Remote services **MUST NOT** be able to access plaintext user content, except where the Canon explicitly carves out a remote-processing path with stated exposure bounds and threat assumptions.
- **PC-3.2** Telemetry **MUST** be optional and minimized; defaults **SHOULD** avoid collecting data that reconstructs sensitive behavior, and **MUST NOT** rely on covert signals (e.g., timing, crash beacons) to circumvent telemetry-off.

PC-4 Crisis UX Controls (Cognitive Load Preservation)

- **PC-4.1** The system **MUST** provide an Accessible Mechanism to enter/exit protective interaction modes and **MUST** map these to $S_1/S_2/S_3$ transitions as defined in the Canon.
- **PC-4.2** In protective modes, the system **MUST** suppress nonessential prompts and preserve Safe Exit in a fixed, predictable location and gesture budget.

Transition authority note (Canon alignment): Advisory signals (e.g., erratic timing, sensor variance) **MAY** inform user-facing suggestions, but they **MUST NOT** directly trigger externally observable mode/presentation changes (especially concealment/evasion) without explicit user intent. When the system takes automatic action under uncertainty, it **SHOULD** be limited to silent hardening that reduces exposure and increases reversibility (e.g., pause nonessential network use, defer sync, tighten telemetry to off, stage destructive actions).

Silent hardening vs outward presentation (reconciliation): Silent hardening **MAY** include reversible, non-identifying physical or operational changes (e.g., muting sounds/vibration, reducing screen brightness, deferring background sync, pausing nonessential network calls). By contrast, outward-presentation changes that plausibly indicate concealment/protection (e.g., a prominent “Safety Mode Activated” banner, a sudden conspicuous switch to a decoy interface, or unexpected removal of visible data cues) **SHOULD** be user-triggered and designed to avoid coercion-relevant tells.

Rapid exit vs effortless descent (S3 nuance): Downward transitions **SHOULD** remain effortless for the user, but in coercive contexts (S_3) the *mechanism* for rapid exit **SHOULD** be non-obvious to an observer and **SHOULD** avoid conspicuous on-screen labeling (e.g., avoid a large “Exit Coercion Mode” button). Prefer user-configurable, accessible, and documented mechanisms such as a safety/duress credential, a consistent placement that can be learned by the user, or an assistive-technology-friendly shortcut that is not semantically labeled as a protective action in the visible UI.

Multi-step confirmation examples (non-prescriptive): A short waiting period plus explicit reaffirmation; a press-and-hold gesture; a small cognitive task (non-sensitive) that cannot be satisfied by muscle memory alone; mixed-modality confirmation (e.g., a hardware button plus an on-screen confirmation); or authentication via a pre-established safety/duress credential.

PC-5 Coercion and Duress Controls (Asymmetric Power Defense)

- **PC-5.1** The system **MUST** support a user-controlled duress or concealment mechanism with predictable, documented, and where applicable reversible behavior.
- **PC-5.2** The system **MUST** provide offline export in non-proprietary formats without vendor mediation. At least one export **SHOULD** be human-

readable (e.g., CSV or Markdown) in addition to machine-readable formats (e.g., JSON).

- **PC-5.3** Neutral presentation modes **MUST** avoid externally observable “tells” that increase coercion risk; any neutral interface **SHOULD** remain plausibly functional and avoid sudden or conspicuous transformations, and **SHOULD** be empirically tested against naive and informed observers to confirm no obvious tells.
- **PC-5.4** The system **SHOULD** support a user-triggered safety routine that can destroy or disable local access keys (cryptographic erasure), with clear disclosure of tradeoffs and bounded guarantees.

Forensic residue tension (recovery vs traces): Protective modes **SHOULD** minimize durable traces that could later be used against the user (e.g., precise timestamps of mode activation, detailed interaction histories, or reconstructive metadata). Where any protective-mode indicators or recovery aids are stored, they **SHOULD** be (1) coarse and non-reconstructive, (2) encrypted at rest with the same boundary as Protected Records, and (3) user-controlled (view/purge) without requiring network or vendor intervention.

PC-5.3 tell evaluation guidance (scaled, non-normative):

- **Self-assessment (Level A/B):** Run a scripted “spot the difference” check with at least 2 naive observers (not involved in implementation). A “consistent tell” can be treated as: at least two observers independently flag the same concrete cue (banner text, missing data cue, sudden interface swap) without being prompted.
- **Audit-grade (Level C):** Use an independent-rater protocol with a pre-registered rubric and clearly defined tell classes (e.g., branding/UI swaps, missing content cues, brightness/haptics changes, timing anomalies). Report rater count, rater independence, and an inter-rater reliability measure; treat any high-agreement cue as a FAIL candidate requiring redesign or disclosure.

This evaluation is inherently human-factors work; the purpose is to reduce obvious tells, not to claim perfect undetectability.

Timing/latency tell note (non-normative): Even when two presentations look identical, a consistent difference in load time, time-to-first-interaction, or transition latency can function as a tell for sophisticated observers (or tooling). Where neutral presentation gates access to different partitions (e.g., decoy vs encrypted), teams **SHOULD** measure latency distributions across representative devices and conditions.

- **Detection approach:** record time-to-first-render and time-to-first-interaction for both modes across multiple runs; treat consistent, mode-specific deltas as a tell candidate.
- **Mitigation options:** equalize rendering paths where feasible, and/or add bounded jitter/delay to reduce distinguishability. Any introduced

delays **MUST** be weighed against CLF impacts and should be disclosed as a trade-off rather than claimed as a guarantee.

Normative strength note (MUST vs SHOULD): In this Companion, **MUST** is used when a control is required to support the Canon’s stated protective claims for the target profile; **SHOULD** is used when the control is strongly desirable but plausibly contraindicated for some populations due to Type I harm risk (irreversible loss) or when multiple non-equivalent design patterns exist. When a system chooses not to implement a **SHOULD** control, it **SHOULD** document a rationale and an alternative mitigation.

For example, **PC-5.4** is **SHOULD** (not **MUST**) because cryptographic erasure can materially increase Type I harm risk for some users if triggered accidentally or under coercion; systems **MAY** instead implement reversible concealment/decoy patterns, but **MUST** disclose guarantees, limits, and recovery behavior.

PC-6 Supply Chain and Update Integrity Controls

- **PC-6.1** Updates to security-critical components **MUST** be authenticated (e.g., signing) and subject to change-control.
- **PC-6.2** Build and dependency practices **SHOULD** support traceability (e.g., SBOM, dependency pinning) for auditability.
- **PC-6.3** Security-critical builds **SHOULD** be reproducible or have an equivalent independent build-verification path.

2) Evidence Artifacts & Test Modalities (Illustrative)

Protective properties should be supported by multiple evidence types:

- **Design-time evidence:** threat model, dataflow diagrams, mode/state transition logic, explicit out-of-scope declarations.
- **Build-time evidence:** SBOM, dependency policies, update signing, change-control for security-critical code paths.
- **Run-time evidence:** reproducible scenario tests for network loss, auth service failure, crash/reboot recovery, offline export generation.
- **Human-factor evidence:** scenario-based evaluations emphasizing safe exit, override/exit in modes, comprehension under stress, and post-crisis reconstruction.

Threat modeling guidance (lightweight): At minimum, threat models **SHOULD** enumerate (1) assets (Protected Records, keys, identifiers), (2) adversaries (coercer, institution/operator, malicious insider, passive network observer), (3) entry points (UI, export pipeline, update channel, crash reporting), and (4) explicit assumptions and exclusions. Teams **MAY** use STRIDE/LINDDUN-style prompts as checklists; the key requirement is that the threats tested match the threats claimed.

Human-factor evaluation guidance (minimum): Scenario studies SHOULD document participant recruitment constraints, ethics/safety protocol (including debrief and opt-out), input constraints (e.g., motor impairment simulation), and inter-rater reliability for rubric scoring. Where appropriate, teams MAY add a subjective workload measure (e.g., a short standardized workload rating) alongside objective step/time measures.

Telemetry/covert-signal audit techniques (suggested): Combine (1) network capture under representative workflows, (2) static inspection of crash reporter / analytics integrations and configuration defaults, and (3) runtime log/event inspection to detect “telemetry-off” bypass paths (timing beacons, crash beacons, background reconciliation pings).

Evidence burden and tiers (non-normative): This Companion describes an audit-grade evidence posture. Teams with limited resources MAY adopt a staged approach as long as they do not overclaim protection.

- **Level A (Self-assessed / community):** control statements + design notes + scripted manual tests + local network capture; clearly label results as self-assessed.
- **Level B (Independent review):** Level A plus an external reviewer for security-critical paths and reproduction of a subset of scenario tests.
- **Level C (Audit-grade):** Level B plus formalized test harnesses, adversarial testing, and documented inter-rater reliability where human judgment is part of the control (e.g., PC-5.3).

Where a team adopts Levels A or B, any public claim SHOULD explicitly state the evidence level and known gaps.

Limits of telemetry auditing (non-normative): No audit can perfectly prove the absence of covert signals in a hostile codebase. The goal is to make bypass paths difficult to hide and easy to detect through layered evidence (build-time dependency review, runtime traffic capture, and reproducible tests) and through change-control for telemetry-bearing components.

Coarse, non-reconstructive logging example (non-prescriptive): Record that an error occurred while operating in S_1 or S_2 , but do not record sensor traces, timing features, or navigation sequences that produced an advisory signal.

Population scope note (minors/guardianship): The Canon’s default subject model is a sovereign user. If the protected subject is a child, or if a legal guardian is the likely coercer, teams MUST NOT claim Canon-level protection without a profile-specific threat model and explicit disclosure of consent/authority assumptions (including how the system handles guardian access, compelled disclosure, and reporting obligations, where applicable).

Compact mapping (control $\rightarrow$ evidence $\rightarrow$ test)

Control objective	Example control statement
PC-1 Local Authority	Essential Operations succeed offline
PC-2 Reversibility	Destructive Actions reversible within window
PC-3 Exposure Minimization	No plaintext or reconstructive metadata egress
PC-4 Crisis UX	Safe Exit remains reachable and predictable
PC-5 Duress/Export	Duress + offline export without vendor
PC-5 Duress/Export (Advanced)	Neutral presentation has no obvious tell; crypto-erasure routine is user-tri
PC-6 Supply Chain	Updates authenticated and auditable

3) PLS Measurement Harness Outline (Provisional)

This outlines a minimal measurement harness for each PLS component. Implementations MAY vary; measurements SHOULD be reproducible, documented, and resistant to gaming.

- **RQ (Reversibility Quotient):** Execute all Destructive Actions exposed in the UI plus at least one API-level/destructive code path (where applicable) under simulated S_1/S_2 conditions; report the fraction of Destructive Actions that are locally reversible within the restoration window. Only byte-identical or record-hash-equivalent restores count as reversible. For record-hash-equivalent, compute the hash over a canonical plaintext representation (post-decrypt) and ignore benign serialization differences; partial or approximate recoveries do not count.
- **ER (Exposure Ratio):** Capture all network egress and inspect payload contents (not configuration only) to determine whether user-generated content (or Reconstructive Metadata) is transmitted in plaintext. The denominator (total sensitive bytes created/modified) MUST be measured directly from local storage writes within the test window (not inferred, estimated, or sampled from egress volume). This is a test-lab measurement and MUST NOT be implemented as production telemetry. The test window MUST include a declared minimum duration and/or completion of a declared representative workflow suite.
- **LAI (Local Authority Index):** Run Essential Operations with network disabled and with remote identity services unavailable, including reboot/crash recovery and the metered-data stress variant (0KB remaining on a metered plan; background data disabled). Score LAI on a 0–3 scale: 0 = Essential Operations fail offline; 1 = partial functionality or inconsistent across reboot; 2 = full offline function but with nags/soft blocks; 3 = full offline function with no nags/blocks under metered constraints.
- **CLF (Cognitive Load Factor):** Under crisis/duress routing, measure interaction steps and time-to-completion for a fixed PLS task list (defined per system profile and aligned to Canon scope) and verify suppression of non-critical prompts. Stress variant: simulate “drug-induced dissociation / motor constraint” by allowing only one-finger input plus a fixed 2-second delay between actions; verify Safe Exit remains reachable, predictable, and

does not time out into a higher-risk state. CLF MAY be reported as a normalized score against a reference UI.

- **ΔS (Sovereignty Delta):** Report three axes (key control, data access, export), each scored 0–3, where 3 = fully user/local; 2 = requires non-exclusive vendor assistance; 1 = requires exclusive vendor action or proprietary tooling; 0 = not available.

PLS measurement notes (non-normative):

- **ER subjectivity control:** The “representative workflow suite” SHOULD be enumerated and versioned (inputs, durations, and coverage rationale). If two suites exist (clinical vs legal), report ER per suite.
- **ER denominator feasibility:** Measuring “sensitive bytes created/modified” generally requires lab instrumentation of local persistence (e.g., storage-layer byte counters or deterministic record-size accounting). This is expected to be non-trivial; do not substitute approximate proxies without disclosing them.
- **CLF is not only steps/time:** Steps and time are necessary but not sufficient. Where CLF is used for comparative evaluation, pair objective measures with at least one documented subjective workload/comprehension measure and report confidence limits rather than implying clinical precision.

4) Drift, Frequency, and Anti-Gaming Notes (Draft)

- **Frequency:** evidence for controls tagged security-critical MUST be refreshed for every release that modifies their code paths; for other controls, at least once per major version or annually, whichever comes first.
- **Drift rule:** change records affecting protective subsystems MUST include an impact matrix listing impacted control families and the required delta-evaluation tests.
- **Anti-gaming:** if scoring is used, include adversarial testing to detect performative compliance and metric gaming. Adversarial testing SHOULD be performed by a party that did not author the control implementation or primary test harness.

Anti-gaming (signal spoofing): If advisory signals are used to suggest state changes, test that an attacker can neither force an externally observable transition nor lock the user into a riskier presentation state by manipulating those signals. A safe default under ambiguous conditions is silent hardening plus user-triggered transitions only.

5) Key Recovery Design Surface (Outline)

Key recovery is a required design surface with bounded guarantees:

- **Type I harm risk:** no recovery → irreversible loss for users in vulnerability.

- **Type II harm risk:** recovery expands coercion/exposure surface.

Candidate approaches (non-exhaustive):

- **User-held recovery kit:** printable/offline recovery material with clear disclosure of risks.
- **Social recovery:** secret-sharing across trusted contacts with explicit coercion-risk modeling.
- **Hardware-backed keys:** platform secure hardware where available, with clear fallback behavior.

Additional constraints:

- Systems MAY choose a “no recovery” posture only where the Canon’s harm model explicitly documents the resulting Type I risk and justifies it for the target population.
- Social recovery MUST explicitly model threats where a coercer controls some but not all trustees.
- For hardware-backed keys, fallback behavior (e.g., device replacement, OS reinstall) MUST be explicitly documented and exercised in tests under S_1/S_2 conditions.

User-driven risk trade-off note (non-normative): A system MAY allow an informed user to select a “no recovery” posture if (1) the resulting Type I risk is disclosed in plain language, (2) the user can demonstrate comprehension at the time of choice (e.g., an explicit acknowledgement), and (3) the choice is reversible within a safe window where feasible. Systems MUST NOT treat user choice as a substitute for documenting and justifying the harm trade-off for the target population.

Evaluation targets should include recovery success under realistic constraints, coercion-resistance properties, and safe failure behavior when recovery is not possible.

6) Worked Auditor Walkthrough (Example)

This section illustrates what “proof” looks like for a single control. It is intentionally written as an audit procedure and evidence checklist, not as a mandate for any particular cryptographic design.

Walkthrough: PC-5.4 Cryptographic Erasure (Destroy or disable local access keys)

Field	Checklist
Control	PC-5.4: The system SHOULD support a user-triggered safety routine to
Audit intent	Confirm (1) a user-controlled “emergency brake” exists for coercive control
Scope limits (required disclosures)	(1) No claim of protection against compromised OS, malware/spyware, or
Evidence (design-time)	(1) Threat model excerpt covering coercive access and physical device se

Field	Checklist
Evidence (build-time)	(1) Change-control record marking cryptographic erasure as security-critical
Procedure (run-time)	Stop rule: stop the test at the first step where expected behavior is not met
Expected results (pass/fail)	Pass: Protected Records cannot be decrypted/accessed post-trigger with the key
Anti-gaming checks	Confirm the routine is not trivially bypassable (mode toggle/settings). Confirm that the routine is not bypassable by the user

Walkthrough: PC-2.3 Temporal Buffering (Staged irreversibility)

Field	Checklist
Control	PC-2.3: Irreversible outcomes (e.g., hard deletion / garbage collection)
Audit intent	Confirm irreversible data loss cannot occur “in the moment” under S_1/S_2
Scope limits (required disclosures)	(1) This control does not prevent a user from choosing permanent deletion
Evidence (design-time)	(1) A “Deletion Lifecycle Spec” defining: soft-delete, restoration window
Evidence (build-time)	(1) Test plan enumerating destructive operations (single delete, bulk delete)
Procedure (run-time)	Stop rule: stop the test at the first step where expected behavior is not met
Expected results (pass/fail)	Pass: irreversible deletion cannot be finalized during simulated S_1/S_2 ; records are restored
Anti-gaming checks	Confirm there are no “side doors” that finalize deletion (background compaction)

7) Suggested Next Walkthroughs (Non-normative)

- **PC-5.3 Neutral presentation “tell” evaluation:** Independent-rater protocol comparing neutral vs normal mode under naive and informed-observer threat models; include concrete “tell” classes to test (UI affordance changes, brightness/haptics changes, timing anomalies, missing data cues).
- **PC-1.1 Offline guarantee window stress suite:** Validate Essential Operations across interruption conditions (reboot, low battery, storage full/low disk, metered-data constraints), and document any non-IP local dependencies required for Essential Operations.